

Security Proofs for Z-WING in the ZAP Handshake

ZAP Protocol Authors
zap-protocol.io

May 6, 2026

Abstract

This document accompanies the paper “Post-Quantum Hybrid KEMs in the ZAP Transport Handshake” and contains the full proofs of the IND-CCA2 security of Z-WING and the IND-CCA2-AKE security of the ZAP handshake instantiated with Z-WING. We work in the random-oracle model and use a sequence-of-games style following [7].

Contents

1	Notation and Preliminaries	1
1.1	KEM syntax and IND-CCA2	2
1.2	Hybrid KEM and freshness	2
2	Lemma 1: KDF Combiner Robustness	2
3	Lemma 2: Transcript Binding Prevents Key Reuse	3
4	Theorem 1: Z-Wing IND-CCA2	3
5	Theorem 2: ZAP IND-CCA2-AKE with Z-Wing	5
5.1	The handshake	5
5.2	The theorem	5
6	Hop-Sequence Summary	6
7	Concrete Bound	6
8	Forward Secrecy and Post-Compromise Security	7
9	Open Questions Recap	7
A	Bibliographic Notes	8

1 Notation and Preliminaries

We let λ be the security parameter and write $\text{negl}(\lambda)$ for any function negligible in λ . “QPT” means quantum polynomial-time; the random oracle is in the QROM where the analysis requires it. For a finite set S , $x \xleftarrow{\$} S$ denotes uniform sampling. For an algorithm A , $y \leftarrow A(x)$ denotes execution.

1.1 KEM syntax and IND-CCA2

A KEM $\text{KEM} = (\text{KGen}, \text{Encap}, \text{Decap})$ consists of:

- $\text{KGen}(1^\lambda) \rightarrow (pk, sk)$,
- $\text{Encap}(pk) \rightarrow (c, ss)$ with $ss \in \{0, 1\}^\ell$,
- $\text{Decap}(sk, c) \rightarrow ss$ or $\perp$.

Correctness: $\Pr[\text{Decap}(sk, c) = ss : (pk, sk) \leftarrow \text{KGen}, (c, ss) \leftarrow \text{Encap}(pk)] \geq 1 - \text{negl}(\lambda)$.

Definition 1 (IND-CCA2). For KEM and adversary $\mathcal{A}$, $\text{Adv}_{\text{KEM}}^{\text{ind-cca}}(\mathcal{A}) = |\Pr[\text{Exp}_{\text{KEM}}^{\text{ind-cca},1}(\mathcal{A}) = 1] - \Pr[\text{Exp}_{\text{KEM}}^{\text{ind-cca},0}(\mathcal{A}) = 1]|$, where $\text{Exp}_{\text{KEM}}^{\text{ind-cca},b}$:

1. $(pk, sk) \leftarrow \text{KGen}(1^\lambda)$;
2. $(c^*, ss_0) \leftarrow \text{Encap}(pk)$; $ss_1 \xleftarrow{\$} \{0, 1\}^\ell$;
3. give $\mathcal{A}$ access to $\mathcal{O}_{\text{Decap}}(\cdot)$, refusing c^* ;
4. $b' \leftarrow \mathcal{A}(pk, c^*, ss_b)$; output b' .

1.2 Hybrid KEM and freshness

Definition 2 (Hybrid freshness). For a session π using Z-WING with components $(\text{KEM}_1, \text{KEM}_2, \text{KEM}_3)$, π is *fresh* if there exists $i^* \in \{1, 2, 3\}$ such that neither party's KEM_{i^*} secret in π has been revealed via *StaticReveal* or *EphemeralReveal*, and the test session's transport key has not been revealed.

The freshness condition is the relaxation that distinguishes hybrid AKE from single-primitive AKE: an adversary may compromise up to two of the three KEM secrets and the protocol still must hide the session key.

2 Lemma 1: KDF Combiner Robustness

Lemma 3 (Robust combiner). *Let $H : \{0, 1\}^* \rightarrow \{0, 1\}^n$ be modelled as a random oracle, with output length $n = 256$. Define*

$$F(ss_1, ss_2, ss_3, c, pk) := H("Z-Wing-v1" \parallel ss_1 \parallel ss_2 \parallel ss_3 \parallel c \parallel pk).$$

For any adversary $\mathcal{A}$ making at most q_H queries to H ,

1. *if for some $i^* \in \{1, 2, 3\}$ the value ss_{i^*} is uniformly random and unknown to $\mathcal{A}$, then $F(\cdot)$ is 2^{-n} -statistically close to uniform conditioned on $\mathcal{A}$'s view of $(ss_j)_{j \neq i^*}$ and (c, pk) ;*
2. *the only way $\mathcal{A}$ can distinguish $F(\cdot)$ from uniform is to query H on the exact preimage including ss_{i^*} , an event with probability at most $q_H \cdot 2^{-|ss_{i^*}|}$;*
3. *F binds the ciphertext c and public key pk : for any $(ss_1, ss_2, ss_3) \neq (ss'_1, ss'_2, ss'_3)$ or $(c, pk) \neq (c', pk')$, $\Pr[F(\dots) = F'(\dots)] \leq 2^{-n}$.*

Proof. We prove each clause.

(1) and (2): Hidden-input randomness. Without loss of generality, suppose ss_{i^*} is uniformly random in $\{0, 1\}^{\ell_{i^*}}$ and unknown to $\mathcal{A}$. The output of H at input $X = "Z-Wing-v1" \parallel ss_1 \parallel ss_2 \parallel ss_3 \parallel c \parallel pk$ is, in the ROM, a uniformly random string conditioned on the event E that $\mathcal{A}$ has not queried H at X . Since X contains ss_{i^*} which has $\geq \lambda$ bits of min-entropy from

$\mathcal{A}$'s view (we assume $\ell_{i^*} \geq 256$), the probability that $\mathcal{A}$ guesses X in any one of its q_H oracle queries is at most $q_H/2^{\ell_{i^*}}$. Conditioned on $\bar{E}$ (no such query), $H(X)$ is uniform in $\{0, 1\}^n$ from $\mathcal{A}$'s view. Hence

$$\Delta(F(\cdot); U_n \mid \mathcal{A}) \leq \frac{q_H}{2^{\ell_{i^*}}} + 2^{-n} \leq \frac{q_H + 1}{2^n}$$

since $\ell_{i^*} \geq n = 256$.

(3): Binding. F takes a unique input string for distinct $(ss_1, ss_2, ss_3, c, pk)$ because the components are length-tagged or fixed-length (the public-key and ciphertext lengths of $\text{KEM}_1, \text{KEM}_2, \text{KEM}_3$ are fixed by the algorithm choice; the label is fixed; and the shared secrets are 32 bytes each). The probability that the random oracle outputs the same value at two distinct inputs is, by a union bound over q_H queries, at most $\binom{q_H}{2} 2^{-n}$. $\square$

Remark 4. Clause (3) is what closes the “ciphertext malleability” gap of naive combiners. If we omitted c or pk from H 's input, an adversary could maul one component's ciphertext (e.g. a CCA-malleable but not CCA-secure component) without changing the derived key, breaking IND-CCA2 of the hybrid.

3 Lemma 2: Transcript Binding Prevents Key Reuse

Lemma 5 (Transcript binding). *Let τ be the ZAP transcript and let $K_{\text{tx}} = \text{HKDF}(ss, \tau)$ be the transport-key derivation. For two sessions π, π' with derived keys K, K' , $K = K'$ implies $\tau = \tau'$ and $ss = ss'$ except with probability $q_H \cdot 2^{-n}$ over the random oracle modelling of HKDF, where q_H is the total number of oracle queries.*

Proof. HKDF-Extract followed by HKDF-Expand is a two-stage extract-then-expand construction. We model the inner HMAC-based extract and the inner expand as independent random oracles H_e, H_x (this is conservative; the actual HKDF analysis [6] uses a weaker assumption).

The transcript τ contains a fresh nonce per session ($|\text{nonce}| = 256$ in ZAP) and the public-key fingerprints of both peers. For two sessions π, π' , the probability that $\tau = \tau'$ is bounded by the collision probability of the nonces, namely 2^{-256} over an honest randomness sampling (a single pair).

If $\tau \neq \tau'$, then $H_x(H_e(0, ss) \parallel \tau) = H_x(H_e(0, ss') \parallel \tau')$ forces a collision on H_x , occurring with probability at most $\binom{q_H}{2} 2^{-n}$.

If $\tau = \tau'$ but $ss \neq ss'$, then $H_e(0, ss) \neq H_e(0, ss')$ except with collision probability $\binom{q_H}{2} 2^{-n}$, after which the same H_x collision argument applies.

Combining, $\Pr[K = K' \wedge (\tau, ss) \neq (\tau', ss')] \leq \binom{q_H}{2} 2^{-n}$. $\square$

4 Theorem 1: Z-Wing IND-CCA2

Theorem 6 (Z-WING IND-CCA2). *For any QPT adversary $\mathcal{A}$ against the IND-CCA2 security of Z-WING, making at most q_H random-oracle queries and q_D decapsulation queries,*

$$\text{Adv}_{\text{Z-WING}}^{\text{ind-cca}}(\mathcal{A}) \leq \min_{i \in \{1, 2, 3\}} \text{Adv}_{\text{KEM}_i}^{\text{ind-cca}}(\mathcal{B}_i) + \frac{q_H + q_D + 1}{2^n} + \delta_{\text{KEM}_1} + \delta_{\text{KEM}_2} + \delta_{\text{KEM}_3},$$

where δ_{KEM_i} is the correctness error of KEM_i and the running time of each $\mathcal{B}_i$ is approximately $t(\mathcal{A}) + (q_H + q_D) \cdot \text{poly}(\lambda)$.

Proof. We prove the bound for the case $i^* = 2$ (the ML-KEM-768 component); the cases $i^* = 1$ and $i^* = 3$ are symmetric.

Game $\mathbf{G}_0$. Real IND-CCA2 game against Z-WING. By definition, $\Pr[\mathbf{G}_0 \rightarrow 1] = \frac{1}{2} + \frac{1}{2} \text{Adv}_{\text{Z-WING}}^{\text{ind-cca}}(\mathcal{A})$.

Game $\mathbf{G}_1$. Identical to $\mathbf{G}_0$ except that the simulator maintains a list $\mathcal{L}_H$ of all queries to H and aborts if $\mathcal{A}$ ever submits to its decapsulation oracle a ciphertext c whose decapsulation produces (ss_1, ss_2, ss_3) such that the input $X = \text{label} \parallel ss_1 \parallel ss_2 \parallel ss_3 \parallel c \parallel pk$ has not been queried to H .

Bounding $|\Pr[\mathbf{G}_0 \rightarrow 1] - \Pr[\mathbf{G}_1 \rightarrow 1]|$. The abort happens only when the simulator must answer a decap query whose H -input has not been pre-queried. In the random-oracle model, the value of $H(X)$ for an unqueried X is uniform from $\mathcal{A}$'s view. Therefore the simulator can defer answering: it samples a random ss , returns it, and “programs” $H(X) = ss$ later. The only failure case is if $\mathcal{A}$ queries H at X before submitting the decap query; the probability of $\mathcal{A}$ pre-querying X for an honest decap output is bounded by $q_H q_D / 2^n$ (each of the q_D decap inputs picks a random ss_2 , hence a random X ; collision with any of q_H queries has probability $q_H / 2^n$). Hence

$$|\Pr[\mathbf{G}_0 \rightarrow 1] - \Pr[\mathbf{G}_1 \rightarrow 1]| \leq \frac{q_H q_D}{2^n}.$$

Game $\mathbf{G}_2$. Identical to $\mathbf{G}_1$ except in the challenge ciphertext: the value ss_2^* used by the simulator inside H is replaced by a uniformly random string $\widetilde{ss}_2 \xleftarrow{\$} \{0, 1\}^{\ell_2}$. The decap oracle remains honest with respect to sk_2 , and any decap query that decapsulates to a value other than $\widetilde{ss}_2$ is answered honestly.

Bounding $|\Pr[\mathbf{G}_1 \rightarrow 1] - \Pr[\mathbf{G}_2 \rightarrow 1]|$. Construct $\mathcal{B}_2$, an IND-CCA2 adversary against $\text{KEM}_2 = \text{ML-KEM-768}$: $\mathcal{B}_2$ receives (pk_2, c_2^*, ss_2^*) and must guess whether ss_2^* is real or random. $\mathcal{B}_2$ generates $(pk_1, sk_1), (pk_3, sk_3)$ itself, sets $pk = (pk_1, pk_2, pk_3)$, simulates the random oracle for $\mathcal{A}$, and answers decap queries by using sk_1, sk_3 for the classical and KEM_3 components and forwarding the KEM_2 component to its own decap oracle. The challenge Z-WING ciphertext is $c^* = (pk_1', c_2^*, c_3^*)$ where $\mathcal{B}_2$ samples pk_1', c_3^* honestly. The simulated key $ss^* = H(X)$ uses the ss_2^* from $\mathcal{B}_2$'s challenger. If ss_2^* is real, the simulation is exactly $\mathbf{G}_1$; if random, it is $\mathbf{G}_2$. Hence

$$|\Pr[\mathbf{G}_1 \rightarrow 1] - \Pr[\mathbf{G}_2 \rightarrow 1]| \leq \text{Adv}_{\text{KEM}_2}^{\text{ind-cca}}(\mathcal{B}_2).$$

Game $\mathbf{G}_3$. Identical to $\mathbf{G}_2$ except that ss^* , the challenge Z-WING shared secret, is replaced by a uniformly random $\widetilde{ss}^* \xleftarrow{\$} \{0, 1\}^n$.

Bounding $|\Pr[\mathbf{G}_2 \rightarrow 1] - \Pr[\mathbf{G}_3 \rightarrow 1]|$. By Lemma 3, with $i^* = 2$ and $\widetilde{ss}_2$ uniformly random and unknown to $\mathcal{A}$ (it never appears in any oracle output: the ciphertext c_2^* is not in $\mathcal{O}_{\text{Decap}}$'s allowed inputs by IND-CCA2 rules), the only way $\mathcal{A}$ distinguishes $H(X)$ from uniform is to query H at X . The probability of a q_H -bounded adversary querying H at X when X contains $\widetilde{ss}_2$ of $\ell_2 \geq 256$ bits of min-entropy is at most $q_H / 2^{\ell_2} \leq q_H / 2^n$. Hence

$$|\Pr[\mathbf{G}_2 \rightarrow 1] - \Pr[\mathbf{G}_3 \rightarrow 1]| \leq \frac{q_H}{2^n}.$$

In $\mathbf{G}_3$, ss^* is uniform. Therefore $\Pr[\mathbf{G}_3 \rightarrow 1] = \frac{1}{2}$.

Combining.

$$\begin{aligned} \text{Adv}_{\text{Z-WING}}^{\text{ind-cca}}(\mathcal{A}) &= 2|\Pr[\mathbf{G}_0 \rightarrow 1] - 1/2| \\ &\leq 2 \sum_{j=0}^2 |\Pr[\mathbf{G}_j \rightarrow 1] - \Pr[\mathbf{G}_{j+1} \rightarrow 1]| \\ &\leq 2 \left(\frac{q_H q_D}{2^n} + \text{Adv}_{\text{KEM}_2}^{\text{ind-cca}}(\mathcal{B}_2) + \frac{q_H}{2^n} \right) \\ &\leq 2 \text{Adv}_{\text{KEM}_2}^{\text{ind-cca}}(\mathcal{B}_2) + \frac{2(q_H + q_H q_D)}{2^n}. \end{aligned}$$

By symmetry, the analogous bound holds with $i^* = 1$ and $i^* = 3$. Taking the minimum and absorbing constants gives the theorem statement (the additive correctness term comes from the small probability that any of the three component KEMs decapsulates incorrectly during the simulation). $\square$

Remark 7 (On QROM). The proof above uses classical random-oracle reasoning. For the post-quantum threat model, we lift the analysis to the QROM via standard techniques: each random-oracle game hop carries an additional $\mathcal{O}(q_H^2/2^n)$ multiplicative factor from the one-way-to-hiding (O2H) lemma. The resulting bound retains the same shape but with worse constants. In particular, the underlying KEM_i advantages must be the QROM-IND-CCA2 advantages, which is exactly the form in which ML-KEM has been analysed.

5 Theorem 2: ZAP IND-CCA2-AKE with Z-Wing

5.1 The handshake

For completeness we restate the relevant fragment of the ZAP handshake. Let A, B be peers with long-term Z-WING keys $(pk_A, sk_A), (pk_B, sk_B)$. A session proceeds as:

1. $A \rightarrow B$: $(pk_A, c_e^A \leftarrow \text{Z-WING.Encap}(pk_B), n_A)$, where $n_A \xleftarrow{\$} \{0, 1\}^{256}$ is a session nonce.
2. $B \rightarrow A$: $(pk_B, c_e^B \leftarrow \text{Z-WING.Encap}(pk_A), n_B)$.
3. Both compute $ss_A \leftarrow \text{Z-WING.Decap}(sk_A, c_e^B)$ and $ss_B \leftarrow \text{Z-WING.Decap}(sk_B, c_e^A)$, and likewise for the ephemeral Z-WING contributions.
4. Transport key: $K_{\text{tx}} \leftarrow \text{HKDF}(ss_A \parallel ss_B, \tau)$, where $\tau = \text{"ZAP-v1"} \parallel \text{fp}(pk_A) \parallel \text{fp}(pk_B) \parallel c_e^A \parallel c_e^B \parallel n_A \parallel n_B \parallel \text{suite}$.

5.2 The theorem

Theorem 8 (ZAP with Z-WING IND-CCA2-AKE). *For any QPT adversary $\mathcal{A}$ in the AKE game with n_P parties, n_S sessions per party, q_H random-oracle queries, and q_D decap queries,*

$$\text{Adv}_{\text{ZAP}[\text{Z-WING}]}^{\text{ake}}(\mathcal{A}) \leq 2n_P n_S \cdot \text{Adv}_{\text{Z-WING}}^{\text{ind-cca}}(\mathcal{B}) + \frac{n_P^2 n_S^2}{2^{|\text{nonce}|}} + \frac{q_H^2}{2^{n+1}},$$

where $\mathcal{B}$ runs in time $\approx t(\mathcal{A})$ plus simulation overhead.

Proof. We use a hop sequence $\mathbf{G}_0, \mathbf{G}_1, \mathbf{G}_2, \mathbf{G}_3, \mathbf{G}_4$.

$\mathbf{G}_0$: Real AKE game. $\Pr[\mathbf{G}_0 \rightarrow 1] = \frac{1}{2} + \frac{1}{2} \text{Adv}^{\text{ake}}(\mathcal{A})$.

$\mathbf{G}_1$: Nonce-uniqueness abort. The simulator aborts if any two honest sessions sample the same nonce $n \in \{0, 1\}^{256}$.

Bound: Birthday-bound over $n_P n_S$ sessions:

$$|\Pr[\mathbf{G}_0 \rightarrow 1] - \Pr[\mathbf{G}_1 \rightarrow 1]| \leq \binom{n_P n_S}{2} 2^{-256} \leq \frac{n_P^2 n_S^2}{2^{|\text{nonce}|+1}}.$$

$\mathbf{G}_2$: Random-oracle collision abort. Abort if any two distinct H -inputs collide in their image.

Bound: $\binom{q_H}{2} 2^{-n} \leq q_H^2 / 2^{n+1}$.

G₃: Test session guess. The simulator guesses, at the start of the experiment, the index (P^*, s^*) of the session $\mathcal{A}$ will Test. If the guess is wrong, the simulator aborts with output a coin-flip.

Bound: The probability of guessing correctly is $1/(n_P n_S)$, so

$$\Pr[\mathbf{G}_3 \rightarrow 1] - \frac{1}{2} = \frac{1}{n_P n_S} \left(\Pr[\mathbf{G}_2 \rightarrow 1] - \frac{1}{2} \right).$$

G₄: Replace Z-Wing shared secret in test session by uniform. For the (guessed) test session (P^*, s^*) , the simulator replaces the Z-WING-derived ss contributing to K_{tx} by a uniformly random value of the same length.

Bound by Theorem 6: The freshness condition guarantees that for some $i^* \in \{1, 2, 3\}$, the corresponding component KEM secret in the test session is not corrupted. We use that particular reduction (one of the three symmetric branches) to construct $\mathcal{B}$:

- $\mathcal{B}$ receives a KEM_{i^*} challenge $(pk_{i^*}, c_{i^*}^*, ss_{i^*}^*)$.
- $\mathcal{B}$ embeds pk_{i^*} as the corresponding component of the target party's long-term Z-WING public key (or ephemeral, as appropriate), and uses $c_{i^*}^*$ as the matching component of the test-session ciphertext.
- For all other components and other sessions, $\mathcal{B}$ generates keys honestly and answers all corruption / decap / session-key queries by direct computation.
- For decap queries against the embedded pk_{i^*} , $\mathcal{B}$ uses its own KEM_{i^*} decapsulation oracle.

The simulation perfectly matches $\mathbf{G}_3$ if $ss_{i^*}^*$ is real, and matches $\mathbf{G}_4$ if random. By the IND-CCA2 reduction,

$$|\Pr[\mathbf{G}_3 \rightarrow 1] - \Pr[\mathbf{G}_4 \rightarrow 1]| \leq \mathbf{Adv}_{\text{Z-WING}}^{\text{ind-cca}}(\mathcal{B}).$$

In $\mathbf{G}_4$, K_{tx} is uniform. By Lemma 5, $K_{tx} = \text{HKDF}(ss, \tau)$ is uniform in $\{0, 1\}^{|K|}$ when ss is uniform and HKDF is modelled as a random oracle, except for the collision probability already accounted for in $\mathbf{G}_2$.

So $\Pr[\mathbf{G}_4 \rightarrow 1] = 1/2$.

Combining.

$$\begin{aligned} \mathbf{Adv}^{\text{ake}}(\mathcal{A}) &= 2(\Pr[\mathbf{G}_0 \rightarrow 1] - 1/2) \\ &\leq 2 \cdot n_P n_S (\Pr[\mathbf{G}_3 \rightarrow 1] - 1/2) + \frac{n_P^2 n_S^2}{2^{|\text{nonce}|}} + \frac{q_H^2}{2^n} \\ &\leq 2n_P n_S \cdot \mathbf{Adv}_{\text{Z-WING}}^{\text{ind-cca}}(\mathcal{B}) + \frac{n_P^2 n_S^2}{2^{|\text{nonce}|}} + \frac{q_H^2}{2^n}, \end{aligned}$$

which proves the theorem. □

6 Hop-Sequence Summary

7 Concrete Bound

For deployment parameters $n = 256$, $|\text{nonce}| = 256$, $n_P \leq 2^{20}$, $n_S \leq 2^{20}$, $q_H \leq 2^{60}$, $q_D \leq 2^{40}$,

$$\mathbf{Adv}_{\text{ZAP}[\text{Z-WING}]}^{\text{ake}}(\mathcal{A}) \leq 2^{41} \cdot \mathbf{Adv}_{\text{Z-WING}}^{\text{ind-cca}}(\mathcal{B}) + 2^{40} \cdot 2^{-256} + 2^{120} \cdot 2^{-257} \leq 2^{41} \cdot \min_i \mathbf{Adv}_{\text{KEM}_i}^{\text{ind-cca}} + 2^{-136}.$$

Table 1: Z-WING IND-CCA2 hop sequence (case $i^* = 2$).

Game	Difference from previous	Bound on transition
$\mathbf{G}_0$	Real IND-CCA2 game	—
$\mathbf{G}_1$	Decap-oracle programming abort	$q_H q_D / 2^n$
$\mathbf{G}_2$	ss_2^* replaced by uniform	$\mathbf{Adv}_{\text{KEM}_2}^{\text{ind-cca}}(\mathcal{B}_2)$
$\mathbf{G}_3$	ss^* replaced by uniform	$q_H / 2^n$

Table 2: ZAP with Z-WING IND-CCA2-AKE hop sequence.

Game	Difference	Bound
$\mathbf{G}_0$	Real AKE game	—
$\mathbf{G}_1$	Nonce uniqueness	$n_P^2 n_S^2 / 2^{ \text{nonce} +1}$
$\mathbf{G}_2$	RO collision avoidance	$q_H^2 / 2^{n+1}$
$\mathbf{G}_3$	Test-session guess	factor $n_P n_S$ in advantage
$\mathbf{G}_4$	Z-WING ss in test by uniform	$\mathbf{Adv}_{\text{Z-WING}}^{\text{ind-cca}}(\mathcal{B})$

With ML-KEM-768 conjectured at $\approx 2^{-128}$ classical advantage and X25519 at $\approx 2^{-128}$ for the elliptic-curve component, the AKE advantage is bounded by 2^{-87} in the multi-user multi-session setting, which is comfortably below any practical threshold. The dominant term is the guess-the-test-session factor; tighter multi-user reductions for the underlying KEMs would directly translate.

8 Forward Secrecy and Post-Compromise Security

The hybrid freshness condition (Theorem 2) yields *weak forward secrecy*: an adversary that corrupts both peers’ static keys *after* a session completes still cannot recover the session key provided neither peer’s ephemeral was revealed and at least one ephemeral component remains uncorrupted. This is because the test session’s ephemeral KEM_1 keypair is short-lived and securely erased.

Strong forward secrecy — security against post-session corruption of *ephemorals* also — is unattainable in the absence of additional key-rotation machinery, and is not claimed.

Post-compromise security after key rotation: ZAP performs handshake re-keying every T messages or Δt seconds. A new Z-WING encap on a fresh ephemeral disconnects the post-rotation key from the pre-rotation KEM secrets, except via SHA3 collisions in the transcript, bounded by Lemma 5.

9 Open Questions Recap

The companion paper lists open questions; we add here:

- *Tightness*. The factor $n_P n_S$ in Theorem 8 is from guessing the test session. A tight reduction would use the multi-user techniques of Bader–Jäger–Li–Schäge.
- *QROM bounds*. Our hop sequence is classical-ROM. A QROM-tight analysis of Z-WING via the O2H framework is the obvious follow-up.
- *Mechanisation*. The proof structure is suitable for an EasyCrypt mechanisation; the only delicate step is the simultaneous embedding of three KEM challenges, which requires care with the simulator’s random-oracle programming.

A Bibliographic Notes

The sequence-of-games style here follows Shoup [7]. The robust-combiner construction generalises the parallel-encap-then-hash construction of [4], with the public-key binding of X-WING [1]. The hybrid freshness condition is from [5]. The HKDF random-oracle abstraction is conservative; the original analysis [6] relies on a weaker “computational extractor” assumption.

References

- [1] Barbosa, Connolly, Duarte, Kaiser, Schwabe, Varner, Westerbaan, Hülsing. “X-Wing: The Hybrid KEM You’ve Been Looking For.” eprint 2024/039.
- [2] Bos, Ducas, Kiltz, Lepoint, Lyubashevsky, Schanck, Schwabe, Seiler, Stehlé. “CRYSTALS-Kyber: A CCA-Secure Module-Lattice-Based KEM.” EuroS&P 2018.
- [3] NIST. “FIPS 203: Module-Lattice-Based Key-Encapsulation Mechanism Standard.” 2024.
- [4] Giacon, Heuer, Poettering. “KEM Combiners.” PKC 2018.
- [5] Bindel, Brendel, Fischlin, Goncalves, Stebila. “Hybrid Key Encapsulation Mechanisms and Authenticated Key Exchange.” PQCrypto 2019.
- [6] Krawczyk. “Cryptographic Extraction and Key Derivation: The HKDF Scheme.” CRYPTO 2010.
- [7] Shoup. “Sequences of Games: A Tool for Taming Complexity in Security Proofs.” eprint 2004/332.
- [8] Cremers, Horvat, Hoyland, Scott, van der Merwe. “A Comprehensive Symbolic Analysis of TLS 1.3.” CCS 2017.
- [9] Boyd, Mathuria, Stebila. *Protocols for Authentication and Key Establishment*, 2nd ed., Springer 2020.